Security-Aware Modeling and Efficient Mapping for CAN-Based Real-Time Distributed Automotive Systems

Chung-Wei Lin, Qi Zhu, and Alberto Sangiovanni-Vincentelli

***Abstract*—Security has become a critical issue for automotive electronic systems. To protect against attacks, security mechanisms have to be applied, but the overhead of those mechanisms may impede system performance and cause violations of design constraints. To remedy this problem, we proposed an integrated mixed integer linear programming (MILP) formulation that is the first to address both security and safety constraints during system mapping for controller area network (CAN) based systems [10]. However, its signal-based security constraints do not fully reflect real security requirements, and its objective function is to minimize functional path latencies rather than minimize security risk. Furthermore, its MILP-based approach has high computation complexity. In this work, we present a new formulation that defines path-based security constraints and minimizes security risk directly, and propose a new heuristic algorithm to solve the formulation efficiently. Experiments on an industrial example show that our new algorithm achieves comparable solution quality as the MILP-based approach with much better efficiency.**

***Index Terms*—Automotive systems, cyber-physical systems, design space exploration, embedded systems, security.**

I. Introduction

HAVING more external interfaces increases the possibility of automotive systems being attacked and raises the importance of secure automotive system design, as pointed out in a number of previous works [3], [5]–[8], [11], [13]. In particular, the work in [3] shows that a malicious attacker can get access to electronic control units (ECUs) or in-vehicle communication networks and then take control of a vehicle. The work in [5] demonstrates possible attacks on the controller area network (CAN) [1], [2], the most used protocol in current in-vehicle communications.

Manuscript received June 01, 2014; accepted August 16, 2014. Date of publication September 04, 2014; date of current version February 24, 2015. This work was supported in part by the TerraSwarm Research Center, one of six centers supported by the STARnet phase of the Focus Center Research Program (FCRP), by a Semiconductor Research Corporation Program sponsored by MARCO and DARPA, and by the Industrial Cyber-Physical Systems Center (iCyPhy). This manuscript was recommended for publication by Y. Fei.

C.-W. Lin and A. Sangiovanni-Vincentelli are with the Department of Electrical Engineering and Computer Sciences, University of California, Berkeley, Berkeley, CA 94720 USA (e-mail: cwlin@eecs.berkeley.edu; alberto@berkeley.edu).

Q. Zhu is with the Department of Electrical and Computer Engineering, University of California, Riverside, Riverside, CA 92521 USA (e-mail: qzhu@ece.ucr.edu).

Color versions of one or more of the figures in this letter are available online at http://ieeexplore.ieee.org.

Digital Object Identifier 10.1109/LES.2014.2354011

To protect against attacks on the CAN network, security mechanisms should be applied [4], [9], [12]. However, the overhead of those mechanisms may cause violations of design constraints. For instance, if message authentication codes (MACs) are used for message authentication, the transmission time of messages will increase due to increased message lengths, which may lead to violations of timing constraints and cause system failure.

To remedy this problem, we proposed an integrated mixed integer linear programming (MILP) formulation [10] that is the first to address both security and safety constraints during system design.

The work in [10] has a few major limitations. First, its signal-based security constraints do not fully reflect real security requirements in embedded control systems. In those systems, the consequences of security attacks typically manifest as certain sensor-to-actuator functional paths (a path is a sequence of tasks and signals) do not perform as intended. Therefore, security requirements should be defined based on functional paths, rather than individual signals. Second, the objective function is to minimize the summation of the worst-case end-to-end latencies of functional paths, while in many cases, minimizing security risk under latency constraints is the design goal. Last, the MILP-based approach has very high computation complexity. A fast greedy heuristic is also proposed in [10], but the solution quality is far from the MILP-based approach. Therefore, an efficient *and* effective approach is desired for this problem.

In this letter, we present a new formulation which models the path-based security constraints and minimizes security risk directly. Based on the new formulation, the risk that a functional path being compromised can be bounded and minimized. We propose a new heuristic algorithm to solve the problem efficiently. The new algorithm can solve the problem much more efficiently with comparable solution quality, compared with the MILP-based approach in [10].

The rest of this letter is organized as follows. Section II introduces the system model. Section III discusses the new formulation. Section IV presents the new algorithm. Section V reports experimental results. Section VI concludes the letter.

II. System Model

The system model follows that in [10]. As shown in Fig. 1, the functional model is a task graph including a set of tasks $\mathcal{T} = \{\tau_1, \tau_2, \ldots, \tau_{|\mathcal{T}|}\}$ and a set of signals $\mathcal{S} = \{\sigma_1, \sigma_2, \ldots, \sigma_{|\mathcal{S}|}\}$. Tasks are activated periodically and communicate with other tasks through signals. The architecture

1943-0663 © 2014 IEEE. Personal use is permitted, but republication/redistribution requires IEEE permission.
See http://www.ieee.org/publications_standards/publications/rights/index.html for more information.
Authorized licensed use limited to: Notre Dame University - Louaize. Downloaded on September 21,2026 at 18:56:04 UTC from IEEE Xplore. Restrictions apply.

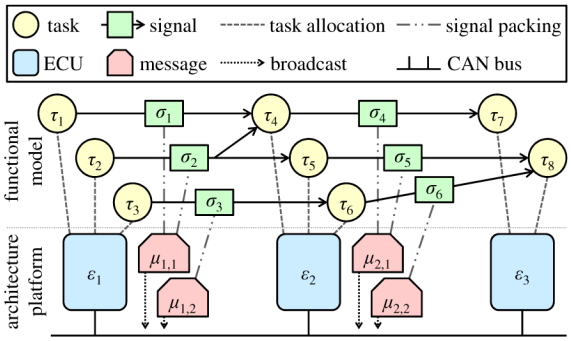


Fig. 1. System model of a CAN-based distributed system [10].

model is a distributed CAN-based platform including a set of ECUs $\mathcal{E} = \{\varepsilon_1, \varepsilon_2, \ldots, \varepsilon_{|\mathcal{E}|}\}$ and a CAN bus connecting all the ECUs. Each ECU ε_k can send a set of messages $\mathcal{M}_k = \{\mu_{k,1}, \mu_{k,2}, \ldots, \mu_{k,|\mathcal{M}_k|}\}$. ECUs are assumed to support preemptive priority-based task scheduling. The bus uses the standard CAN bus arbitration model that features nonpreemptive priority-based message scheduling [1].

A path $\pi = [\tau_{i_1}, \sigma_{j_1}, \tau_{i_2}, \sigma_{j_2}, \ldots, \sigma_{j_{|\pi|-1}}, \tau_{i_{|\pi|}}]$ is an interleaving sequence of tasks and signals, where τ_{i_1} is the source, $\tau_{i_{|\pi|}}$ is the destination, and $|\pi|$ is the length of π. Sources catch external events, while destinations activate actuators. The worst-case end-to-end latency of a path is the largest possible time interval that is required for the change of the input (or sensed) value at the source to be propagated and cause a value change (or an actuation response) at the destination, which needs to be within a given deadline. We use $\mathcal{P}$ to denote the set of paths.

In [10], the security mechanism in [9] is extended by assigning *receiving group* to allow multiple ECUs to use the same secret key and share one MAC in a message. If two ECUs use the same secret key in a message, there are possible *direct attacks* between them—an attacker takes control of one ECU, uses the shared secret key, and makes a message accepted by the other ECU. On the other hand, if an attacker plugs in a CAN bus or takes control of an ECU without the shared secret key, it can only perform *indirect attacks*—it tries to guess a MAC and attempts to make a message accepted by a receiving ECU (receiver). The receiving group assignment provides more design flexibility, compared with traditional one-key-for-all key distribution or pair-wise key distribution. We use $\mathcal{G}_{k,l}$ to denote the set of receiving groups of $\mu_{k,l}$ and $\Gamma_{k,l,g}$ to denote the g-th receiving group in $\mathcal{G}_{k,l}$.

During mapping, as shown in Fig. 1, the tasks are allocated onto ECUs, and the signals are packed into messages. Static priorities are assigned to tasks and messages. The design space of task allocation, signal packing, priority assignment, and receiving group assignment is explored with a set of objectives and constraints.

III. Formulation

In this section, we introduce our new formulation, focusing on the new path-based security constraints and the new objective function. The rest of the formulation is similar to [10].

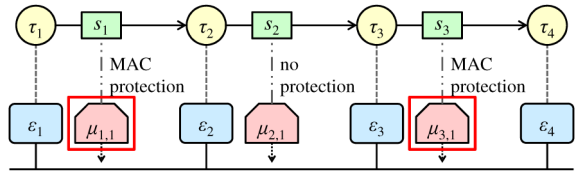


Fig. 2. Security should be modeled by a path-based security constraint considering possible attacks triggering an actuator. Protecting $\mu_{1,1}$ and $\mu_{3,1}$ is not enough because an attacker can still attack $\mu_{2,1}$ and result in triggering τ_4 on ε_4.

A. Path-Based Security Constraints

There are two types of security constraints in [10]. The first one guarantees that the security risk of direct attacks to a signal is not larger than its maximum allowed security risk[1]

$$\forall \sigma_j, \mu_{k,l}, \qquad \sum_{\varepsilon_{k'}, \varepsilon_{k''}} x_{j,k,l,k',k''} \times R_{j,k',k''} \leq R_j \qquad (1)$$

where $R_{j,k',k''}$ is the security risk if $\varepsilon_{k'}$ and $\varepsilon_{k''}$ share the corresponding secret key of σ_j, R_j is the maximum allowed security risk of σ_j, and $x_{j,k,l,k',k''}$ is a binary variable, which is 1 if and only if σ_j is mapped to $\mu_{k,l}$, both $\varepsilon_{k'}$ and $\varepsilon_{k''}$ are receivers of $\mu_{k,l}$, and $\varepsilon_{k'}$ and $\varepsilon_{k''}$ are in the same receiving group of $\mu_{k,l}$.

The second type of security constraints bounds the security risk of indirect attacks by assigning enough MAC lengths

$$\forall \sigma_j, \varepsilon_{k'}, \mu_{k,l}, \Gamma_{k,l,g}, \quad y_{j,k',k,l,g} \times L_{j,k'} \leq L_{k,l,g} \qquad (2)$$

where $L_{j,k'}$ is the required MAC length of σ_j if σ_j is received by $\varepsilon_{k'}$, $L_{k,l,g}$ is the reserved MAC length of $\Gamma_{k,l,g}$, and $y_{j,k',k,l,g}$ is a binary variable, which is 1 if and only if the destination task of σ_j is mapped to ε_k, σ_j is mapped to $\mu_{k,l}$, and $\varepsilon_{k'}$ is in the receiving group $\Gamma_{k,l,g}$

The above individual signal-based security constraints do not fully reflect real security requirements. As stated before, security requirements should be defined based on sensor-to-actuator paths. An example is shown in Fig. 2. Protecting $\mu_{1,1}$ and $\mu_{3,1}$ is not enough because an attacker can still attack $\mu_{2,1}$ and result in triggering τ_4 on ε_4. Therefore, in this letter, we propose to apply the following constraints. The first one guarantees that the security risk of direct attacks to a path is not larger than its maximum allowed security risk

$$\forall \pi_h, \quad \sum_{\sigma_j \in \pi_h} \sum_{\mu_{k,l}} \sum_{\varepsilon_{k'}, \varepsilon_{k''}} x_{j,k,l,k',k''} \times R_{j,k',k''} \leq R_h \qquad (3)$$

where R_h is the maximum allowed security risk of π_h. Similarly, R_h is decided by system designers, and it should depend on how critical π_h is. The second type of security constraints guarantees that the MAC lengths of all signals in a path are long enough

$$\forall \pi_h, \sigma_j \in \pi_h, \varepsilon_{k'}, \mu_{k,l}, \Gamma_{k,l,g}, \quad y_{j,k',k,l,g} \times L_h \leq L_{k,l,g} \qquad (4)$$

where L_h is the required MAC length of any signal in π_h.

Note that Equation (4) can be transformed to Equation (2) by assigning appropriate MAC lengths. However, Equation (3)

[1]If there is no specific mention, $\sigma_j \in \mathcal{S}, \varepsilon_k \in \mathcal{E}, \mu_{k,l} \in \mathcal{M}_k, \Gamma_{k,l,g} \in \mathcal{G}_{k,l}$, and $\pi \in \mathcal{P}$. A constant parameter is in upper case, and a variable is in lower case.

Authorized licensed use limited to: Notre Dame University - Louaize. Downloaded on September 21,2026 at 18:56:04 UTC from IEEE Xplore. Restrictions apply.

cannot be transformed to Equation (1) by distributing the maximum allowed security risk of a path into its signals. This is because there may exist forks in a task graph, and a signal may be involved in many paths. As a result, it is very difficult to just reduce the new formulation to the original formulation, and it is necessary to propose the new formulation.

B. Objective Function

To minimize the security risk of direct attacks, the primary objective function for direct attacks can be defined as

$$\min \sum_{\pi_h} \left(\sum_{\sigma_j \in \pi_h} \sum_{\mu_{k,l}} \sum_{\varepsilon_{k'}, \varepsilon_{k''}} x_{j,k,l,k',k''} \times R_{j,k',k''} \right). \quad (5)$$

If the security risk of direct attacks is minimized, we can also try to increase MAC lengths, which minimizes the security risk of indirect attacks. However, since direct attacks are more threatening, we will focus on minimizing the security risk of direct attacks, as shown in Equation (5).

IV. Algorithm

The MILP-based approach in [10] is not efficient, while the greedy heuristic in [10] does not provide quality solutions. In this work, we propose an efficient and effective heuristic optimization algorithm. It has been observed that task allocation and priority typically have the most impact on objectives, and solving them significantly simplifies the following steps, so they are the first two steps in the proposed approach.

Task Allocation: First, the connectivity of each pair of tasks is computed. The connectivity between two tasks is defined as a weighted summation of the number of times that a signal between the two tasks is in a path and the number of times that a signal between the two tasks is in a security-critical path. This definition makes sure that the higher connectivity between two tasks, the more beneficial (in terms of minimizing worst-case end-to-end latency and minimizing security risk) if they are allocated to the same ECU. After computing the connectivity of each pair of tasks, for each ECU, the most connected pair of tasks (among tasks not allocated yet) is selected, and both of them are allocated to the ECU. Then, the most connected task (among tasks not allocated yet) to all tasks allocated to the ECU is selected and allocated to the ECU. We repeat selecting one task and allocating it to the ECU until allocating the task to the ECU makes the utilization of the ECU exceeding a threshold. If allocating a task to the ECU makes the utilization of the ECU exceeding a threshold, we will consider the next ECU. An example is illustrated in Fig. 3. Given the task graph in Fig. 3(a), we compute the connectivity of each pair of tasks, as shown in Fig. 3(b). After that, τ_3 and τ_4 are selected and allocated to ε_2. Then, τ_1 is selected, but we assume that allocating τ_1 to ε_2 makes the utilization of ε_2 exceeding a threshold. As a result, τ_1 and τ_2 are allocated to ε_1, and the final allocation is shown in Fig. 3(c).

Task Priority Assignment: The task priority is assigned according to the Rate-Monotonic Policy, *i.e.*, tasks with smaller periods have higher priorities. However, if the computation time of a task is larger than a threshold, its priority will become lower. This is because a task with a large computation time may block other tasks for a long time.

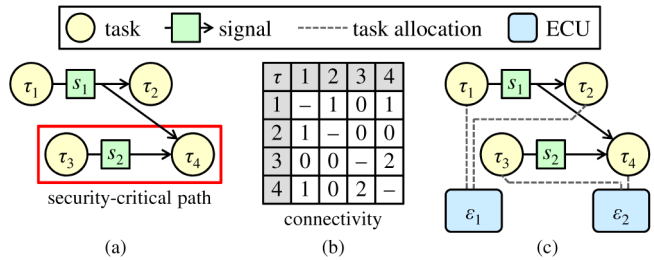


Fig. 3. (a) Given the task graph, (b) compute the connectivity with both weights being 1, and (c) allocate the tasks to the ECUs.

Signal Packing: The signal packing is done in a greedy fashion. For each signal, we try to find a message satisfying the following conditions: the signal and the message have the same period, the source task of the signal is allocated to the source ECU of the message, and there is enough payload space for the signal and its MAC (we assume that each receiving ECU has its own receiving group). If we find a message satisfying the conditions, the signal is packed into the message; otherwise, the signal is packed into an empty message.

Message Priority Assignment: The message priority is also assigned according to the Rate-Monotonic Policy, *i.e.*, messages with smaller periods have higher priorities.

Receiving Group Assignment: The receiving group assignment is done in a greedy fashion. For each receiving ECU of a message, we try to find a receiving group of the message such that adding the ECU into the receiving group does not violate the security constraint for direct attacks, as formulated in Equation (3). If we find a receiving group satisfying the condition, the ECU is assigned to the receiving group, and the MAC length of the receiving group may need to be increased to satisfy the security constraint for indirect attacks, as formulated in Equation (4); otherwise, the ECU is assigned to an empty receiving group. Note that we assume that each receiving ECU has its own receiving group in Step 3, so assigning two receiving ECUs to the same receiving group never increases the length of the message.

V. Experimental Results

We use the same industrial test case in [10]. It supports advanced distributed functions from sensors to actuators and consists of 9 ECUs connected to a CAN [1] or CAN-FD [2] bus with the speed at 500 kb/s. There are only 64 bits for payload in CAN, while CAN-FD allows up to 64 bytes for payload. The functional model consists of 41 tasks and 83 signals. For the safety requirements, 171 paths are selected with deadlines 300 ms or 100 ms. The program is implemented in C/C++, and CPLEX 12.5 is used as the MILP solver. The experiments are run on a 2.5-GHz processor with 4 GB RAM.

There are three settings for both of CAN and CAN-FD. The first one is the same as that in [10]. For the security requirements, 50 signals are selected with required MAC lengths ranging from 10 to 30 bits for CAN and from 64 to 128 bits for CAN-FD. The maximum allowed security risk of a signal is that no more than 2 ECUs can be assigned to the same receiving group. The second setting replaces the signal-based security constraints by the path-based security constraints, where 30 paths are selected, and their required MAC lengths ranging

Authorized licensed use limited to: Notre Dame University - Louaize. Downloaded on September 21,2026 at 18:56:04 UTC from IEEE Xplore. Restrictions apply.

TABLE I
THE COMPARISON BETWEEN THE MILP-BASED APPROACH IN [10], THE GREEDY HEURISTIC IN [10], AND OUR NEW ALGORITHM. "×" MEANS "NO FEASIBLE SOLUTION." IN THE THIRD SETTING, AN OBJECTIVE INCLUDES THE RISKS OF DIRECT ATTACKS AND INDIRECT ATTACKS

	Security Constraints & Objective Function	Signal-Based Constraints & Latency Minimization		Path-Based Constraints & Latency Minimization		Path-Based Constraints & Security Risk Minimization	
		Objective (ms)	Runtime (s)	Objective (ms)	Runtime (s)	Objective (risk)	Runtime (s)
CAN	MILP-Based Approach in [10]	11,069.62	$> 3{,}600$	13,420.64	$> 3{,}600$	0 & 7.05×10^{-3}	$> 3{,}600$
	Greedy heuristic in [10]	23,114.50	< 1.5	—	—	—	—
	Our New Algorithm	13,789.64	< 0.5	13,789.47	< 0.5	0 & 6.05×10^{-3}	< 0.5
CAN-FD	MILP-Based Approach in [10]	11,071.69	$> 3{,}600$	13,422.59	$> 3{,}600$	0 & 3.79×10^{-19}	$> 3{,}600$
	Greedy heuristic in [10]	×	×	—	—	—	—
	Our New Algorithm	13,863.31	< 0.5	13,683.14	< 0.5	0 & 3.25×10^{-19}	< 0.5

from 10 to 30 bits for CAN and from 64 bits to 128 bits for CAN-FD. The maximum allowed security risk of a path is that, considering all signals in the path, no more than 2 to 5 ECUs can be assigned to the same receiving group. The third setting replaces the objective function in the second setting by minimizing security risk as Equation (5).

Table I shows the comparison between our new algorithm, the MILP-based approach in [10], and the greedy heuristic in [10] (it cannot deal with path-based security constraints). In the first setting, the new algorithm gets the objective 13,789.64 ms, which is larger than that of the MILP-based approach. However, the runtime is less than 0.5 s, while the MILP-based approach (which cannot find a feasible solution in such a short time) takes more than 1 hour. Note that the MILP-based approach terminates by timeouts, so it needs more time for a complete run. On the other hand, the new algorithm significantly outperforms the greedy heuristic in [10].

In the second setting, the new algorithm gets the comparable objectives as the MILP-based approach and takes much less runtime. The solution quality is almost the same because the new algorithm with the connectivity concept finds a good task allocation efficiently. On the other hand, although the MILP formulation is optimal for the subproblem of task allocation and task priority, its runtime is too long. Therefore, when it is interrupted by timeouts, its solution quality is not significantly better than that of the new algorithm. This indicates that task allocation and task priority assignment are very crucial for the objective minimization, and adding a good searching algorithm to the new algorithm may lead to even better results (part of our future work).

In the third setting, an objective includes the risks of direct attacks and indirect attacks. The risk of direct attacks is defined in Equation (5), and the risk of indirect attacks is the summation of the probability that an attacker guesses a MAC correctly. The risks of direct attacks are minimized to 0 because each receiving ECU has its own secret keys and MACs, and the higher overheads do not violate any constraint. Our new algorithm has lower risks of indirect attacks because its task allocation tends to allocate the source and destination tasks of a signal in a security-critical path to the same ECU. Given that there is no direct attack, we can increase the MAC lengths to reduce the risk of indirect attacks. In this case, we can further reduce the risks of indirect attacks from 6.05×10^{-3} and 3.25×10^{-19} to 1.53×10^{-5} and 1.09×10^{-37} (almost every MAC can be up to 128 bits with CAN-FD), respectively.

VI. CONCLUSION

In this letter, we presented a new formulation that defines path-based security constraints and minimizes security risk directly. Then, we proposed a new heuristic algorithm to solve the formulation efficiently. Experiments on an industrial example showed that our new algorithm achieves comparable solution quality as the MILP-based approach in [10] with much better efficiency.

REFERENCES

[1] Bosch, "CAN Specification, version 2.0," 1991.
[2] Bosch, "CAN with Flexible Data-Rate White Paper, version 1.1," 2011.
[3] S. Checkoway, D. McCoy, B. Kantor, D. Anderson, H. Shacham, S. Savage, K. Koscher, A. Czeskis, F. Roesner, and T. Kohno, "Comprehensive experimental analyses of automotive attack surfaces," presented at the USENIX Conf. Security, 2011.
[4] B. Groza, S. Murvay, A. Van Herrewege, and I. Verbauwhede, "LiBrA-CAN: A lightweight broadcast authentication protocol for Controller Area Networks," in *Proc. Int. Conf. Cryptology Netw. Security*, 2012, pp. 185–200.
[5] T. Hoppe, S. Kiltz, and J. Dittmann, "Security threats to automotive CAN networks—practical examples and selected short-term countermeasures," in *Proc. Int. Conf. Computer Safety, Rel., Security*, 2008, pp. 11–25.
[6] P. Kleberger, T. Olovsson, and E. Jonsson, "Security aspects of the in-vehicle network in the connected car," in *Proc. IEEE Intell. Veh. Symp.*, 2011, pp. 528–533.
[7] K. Koscher, A. Czeskis, F. Roesner, S. Patel, T. Kohno, S. Checkoway, D. McCoy, B. Kantor, D. Anderson, H. Shacham, and S. Savage, "Experimental security analysis of a modern automobile," in *Proc. IEEE Symp. Security Privacy*, 2010, pp. 447–462.
[8] F. Koushanfar, A. Sadeghi, and H. Seudie, "EDA for secure and dependable cybercars: Challenges and opportunities," in *Proc. ACM/IEEE Design Autom. Conf.*, 2012, pp. 220–228.
[9] C.-W. Lin and A. Sangiovanni-Vincentelli, "Cyber-security for the Controller Area Network (CAN) communication protocol," in *Proc. ASE Int. Conf. Cyber Security*, 2012, pp. 344–350.
[10] C.-W. Lin, Q. Zhu, C. Phung, and A. Sangiovanni-Vincentelli, "Security-aware mapping for CAN-based real-time distributed automotive systems," in *Proc. IEEE/ACM Int. Conf. Computer-Aided Design*, 2013, pp. 115–121.
[11] I. Rouf, R. Miller, H. Mustafa, T. Taylor, S. Oh, W. Xu, M. Gruteser, W. Trappe, and I. Seskar, "Security and privacy vulnerabilities of in-car wireless networks: A tire pressure monitoring system case study," presented at the USENIX Conf. Security, 2010.
[12] A. Van Herrewege, D. Singelee, and I. Verbauwhede, "CANAuth—a simple, backward compatible broadcast authentication protocol for CAN bus," Workshop on Embedded Security in Cars 2011.
[13] M. Wolf, A. Weimerskirch, and C. Paar, "Security in automotive bus systems," Workshop on Embedded Security in Cars 2004.

Authorized licensed use limited to: Notre Dame University - Louaize. Downloaded on September 21,2026 at 18:56:04 UTC from IEEE Xplore. Restrictions apply.